

Rails Health Audit — example-unhealthy-project

Generated 2026-06-23 14:25. Phase 1 (static scan). Full raw tool output is in `raw_original_result/`.

1. Overview (every check, most severe first)

Priority	Category	Tool	Finding	Raw output
● 1	Security	brakeman	4 warning(s)	<code>raw_original_result/brakeman.txt</code>
● 1	Security	bundler-audit	8 vulnerable advisory(ies)	<code>raw_original_result/bundler-audit.txt</code>
● 1	Compliance	license_finder	73	<code>raw_original_result/license_finder.txt</code>
● 3	Performance	fasterer	5 speed suggestion(s)	<code>raw_original_result/fasterer.txt</code>
● 4	Maintainability	rubycritic	score 93.97, 29 smell(s)	<code>raw_original_result/rubycritic.txt</code>
● 4	Rails conventions	rails_best_practices	15 warning(s)	<code>raw_original_result/rails_best_practices.txt</code>
● 4	Maintainability	rubocop	23 offense(s)	<code>raw_original_result/rubocop.txt</code>
● 4	Maintainability	erb_lint	8 ERB offense(s)	<code>raw_original_result/erb_lint.txt</code>
● 5	Tech debt	bundle outdated	2	<code>raw_original_result/outdated.txt</code>

Legend — ● must fix (security / data) · ● should fix (correctness / maintainability) · ● nice to have (style / freshness).

A ⚠️ **skipped check is NOT a pass**. It means the tool could not run in this environment, not that there is nothing wrong. `license_finder` needs a real `bundle install`; `bundle outdated` needs the project's own Ruby (this run used a different Ruby than the project pins). Re-run both in the project's environment to get a real result. *(In this example both ran — it is a real, bundle-installed Rails 8 app — so neither is skipped.)*

2. Action plan

How to read this — cut noise with confidence/criticality: static tools over-report. brakeman tags each warning High / Medium / Weak confidence — fix the **High** ones first; Weak ones are often false positives. bundler-audit tags each advisory Critical / High / Medium — triage **Critical/High**, don't treat all 100+ as equal. So a raw count (e.g. "137 advisories") is a starting point, not 137 separate jobs.

Severity first. Cover every ● and ● finding (one row each); collapse the ● style-level findings into a single row. Use `<br>` for line breaks inside a cell.

#	Pri	Issue (tool, file:line)	Solution	Effort	Raw
1	●	Command injection (brakeman, High) <code>app/controllers/products_controller.rb:28</code> — <code>system("convert #{thumb} ...")</code> shells out with user input.	Never interpolate params into a shell. Use an image library (<code>image_processing</code> / <code>vips</code>) or pass args as an array so no shell is invoked.	M	<code>raw_original_result/brakem</code>

#	Pri	Issue (tool, file:line)	Solution	Effort	Raw
2	●	SQL injection (brakeman, High) app/controllers/products_controller.rb:8 (where("... #{params[:q]} ...")) and :10 (connection.execute with interpolation).	Parameterize: where("name LIKE ?", "%#{q}%"); whitelist params[:sort] against allowed columns.	M	raw_original_result/brakem
3	●	XSS (brakeman, High) app/views/products/index.html.erb:4 — params[:q].html_safe renders raw user input.	Drop .html_safe ; let Rails auto-escape. If HTML is needed, sanitize an allow-list.	S	raw_original_result/brakem
4	●	Vulnerable gem: jwt 2.3.0 (bundler-audit, High) CVE-2026-45363 — empty-key HMAC signature bypass.	Upgrade gem "jwt", ">= 3.2.0", then bundle update jwt .	S	raw_original_result/bundle
5	●	Vulnerable gem: rexml 3.2.4 (bundler-audit, 7 advisories incl. High ReDoS GHSA-2rxp-v6pw- ch6m).	Upgrade gem "rexml", ">= 3.3.9", then bundle update rexml . One bump clears all 7.	S	raw_original_result/bundle
6	●	License compliance (license_finder) 73 dependencies have no approval decision.	Set an allowed-license policy; approve/replace anything copyleft (GPL) that conflicts with the product license.	M	raw_original_result/licens
7	●	rescue Exception (rails_best_practices) app/controllers/products_controller.rb:35 swallows every error, incl. signals.	Rescue StandardError (or a specific class) and re- raise / report the rest.	S	raw_original_result/rails_
8	●	Fat controller / logic in view (rails_best_practices) products_controller.rb:14,41 (@product used >4x) and index.html.erb:13 .	Move create/update body into a service or model method; move the view conditional into a model helper.	M	raw_original_result/rails_
9	●	Maintainability smells (rubycritic, 29) app/models/product.rb — Law of Demeter (owner.address.city), feature envy, complex #s .	Add delegations (delegate :city, to: :address); rename/extract #s ; de- duplicate the create / update blocks.	M	raw_original_result/rubycr
10	●	Slow Ruby idioms (fasterer, 5) app/models/report.rb:6 (select{}.first → detect), :16 (reverse.each → reverse_each); plus config/*.	Swap to the faster idiom each line names — trivial, mechanical.	S	raw_original_result/faster
11	●	Style (rubocop 23 + erb_lint 8) spacing, tag formatting, layout across app/ .	Auto-fix: rubocop -A and erb_lint --autocorrect , then commit the diff.	S	raw_original_result/ruboco raw_original_result/erb_li

3. Phase 2 — runtime checks (follow-up, need app + DB)

These can't be answered by reading code; run them in the project (see audit-dynamic.sh):

- **Data correctness** — active_record_doctor (missing FKs, NOT NULL, unique indexes, model/DB mismatch)
- **Missing indexes** — lol_dba (db:find_indexes)
- **N+1 queries** — bullet (dev/test) or prosopite ; exercise app / run tests
- **Test coverage** — simplecov → run the suite, read coverage/index.html